Security Architecture Overview

Table of content

[Security Architecture Overview](#)
- [Navigation](#)
- [1. Introduction](#)
- [2. System Overview](#)
- [3. Authentication & Access Control](#)
- [4. Data Protection & Encryption](#)
- [5. Infrastructure & Hosting](#)
- [6. Network Architecture](#)
- [7. Fraud Detection & Monitoring](#)
- [8. Backup and Recovery](#)
- [9. Security Threats and Mitigation](#)
- [10. Incident Response](#)
- [11. Compliance & Standards](#)
- [12. Summary](#)

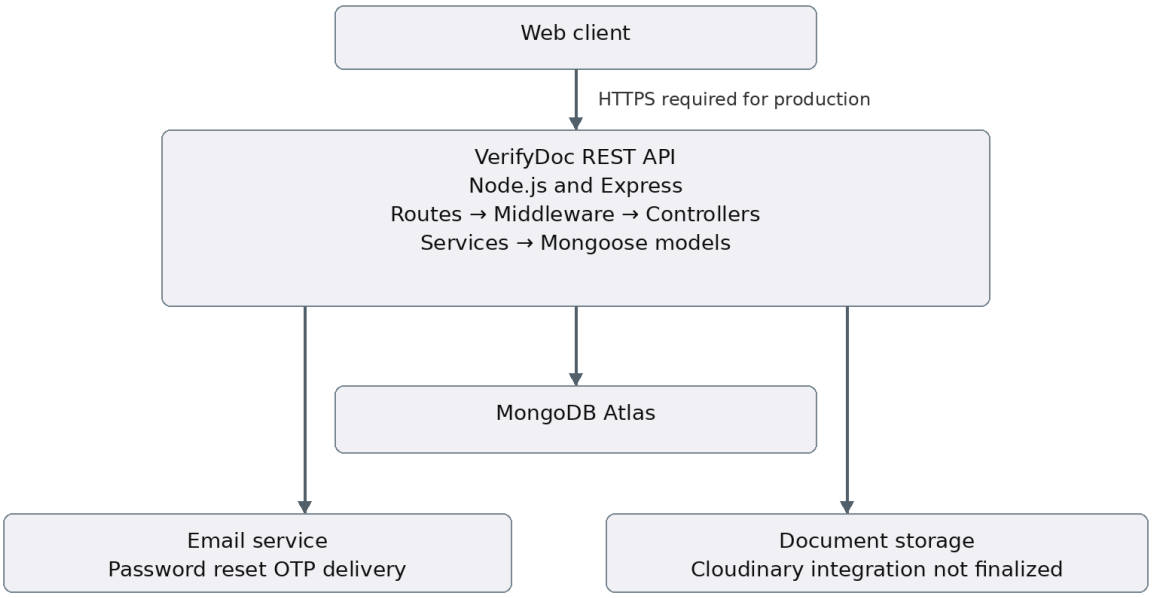
1. Introduction

VerifyDoc is a digital credential-verification platform that allows citizens to manage and share credentials, while approved institutions and employers issue, confirm, and verify them. This document describes how VerifyDoc protects accounts, credentials, and personal information from unauthorized access, alteration, or disclosure.

This overview reflects VerifyDoc's current implementation as of its MVP stage. Several production-level protections remain planned rather than finalized — these are marked clearly throughout rather than presented as complete.

2. System Overview

The backend is built on Node.js and Express, using routes, middleware, controllers, services, and Mongoose models. MongoDB Atlas serves as the database, and an email service supports password-reset OTP delivery.



The diagram represents component relationships; it does not imply private network segmentation or a finalized production deployment.

3. Authentication & Access Control

VerifyDoc requires users to register and log in before accessing protected features.

- **Login method:** Email and password. Passwords are hashed with bcrypt before storage. Two-factor authentication, biometric login, and login-time OTP are not currently implemented.
- **Password recovery:** Uses email-based OTP, which is generated, hashed before storage, sent by email, and verified before a new password can be set. Password-reset OTPs expire after 10 minutes.
- **User roles:** Citizen, Employer/Organization, Institution, and Platform Admin, each with distinct permissions, enforced through role-based authorization middleware.
- **Access boundaries:** Employers and institutions must be approved by the Platform Admin before gaining access. Employers can only view credentials a citizen has explicitly shared with them — a QR code or Credential Number alone does not expose credential information.
- **Sessions and tokens:** VerifyDoc uses JSON Web Tokens (JWTs) for authenticated API access rather than server-side sessions. Tokens are issued with a configured expiration period. A complete refresh-token mechanism, including rotation and forced revocation, has not yet been established for the MVP.

4. Data Protection & Encryption

VerifyDoc handles sensitive information, including personal details, academic and professional credentials, credential status, and verification results. Access to this data is controlled and permission-based.

- **In transit:** The production architecture requires HTTPS for client-to-server communication. The exact TLS version policy has not yet been formally defined or verified.
- **At rest:** User passwords and password-reset OTPs are hashed (bcrypt) — this is a one-way protection, not reversible encryption, and should not be described as such. Database and document encryption at rest depends on the selected hosting provider's configuration, which has not yet been formally documented.

5. Infrastructure & Hosting

MongoDB Atlas is the selected and in-use database platform. Backend deployment work has involved Render, though the final production API hosting architecture has not yet been confirmed. An Atlas configuration using AWS in the EU_SOUTH_2 (Spain) region has been prepared — this reflects a configuration choice, not confirmation of the final live deployment region.

6. Network Architecture

A formal production network architecture — private networking, firewall policy, IP allow-listing, VPC design, WAF configuration, and network segmentation — has not yet been finalized. Current protection operates primarily at the application layer: authentication, role-based authorization, account/entity status checks, ownership checks, and resource permissions, alongside MongoDB Atlas's own database authentication.

7. Fraud Detection & Monitoring

VerifyDoc's MVP trust model relies on credential provenance and institution verification: institution-issued credentials use the institution as the source of truth, while citizen-uploaded credentials require institution review before being treated as verified. Credential states (rejected, revoked, expired) are intended to prevent invalid credentials from continuing to be treated as valid — this is a trust model, not an automated fraud-monitoring engine.

Advanced capabilities — automated forgery detection, AI/OCR tamper detection, anomaly detection, behavioral fraud scoring, and automated fraud reporting — are future considerations, not current or committed capabilities.

8. Backup and Recovery

VerifyDoc does not yet have a formally defined production backup, retention, or disaster-recovery policy — no backup schedule, retention duration, Recovery Point Objective (RPO), Recovery Time Objective (RTO), or recovery procedure has been

established. MongoDB Atlas's backup and restoration capabilities can be assessed and configured for production, but should not be described as active until confirmed.

9. Security Threats and Mitigation

Current application-level protections include: bcrypt password hashing, JWT authentication, hashed and expiring password-reset OTPs, role-based authorization, entity approval controls, account/membership status enforcement, ownership and resource checks, request validation, and environment-based secret configuration.

Controls not yet fully implemented or formally documented include: multi-factor authentication, refresh-token rotation and reuse detection, global session revocation, comprehensive rate limiting, WAF/DDoS protection, intrusion detection, security-event monitoring, and automated breach detection.

These existing controls reduce unauthorized-access risk but should not be represented as a complete account-takeover detection system or verified denial-of-service mitigation strategy.

10. Incident Response

A formal incident response process (dedicated breach detection, notification workflow, and response team) is outside the scope of this capstone project. In the event of a security concern, the responsible development team reviews and addresses it as a priority.

11. Compliance & Standards

The Nigeria Data Protection Regulation (NDPR) is the relevant standard given VerifyDoc's context. Full compliance alignment and certification is a planned consideration beyond this capstone's current scope.

12. Summary

VerifyDoc's current security model combines email/password authentication with hashing, JWT-based API access, role-based authorization, Platform Admin approval of organizations, and citizen-controlled credential sharing. The objective is to protect personal information and credential records, prevent unauthorized access and fraud, and maintain the integrity of verification results.